

Seguridad (Security)

ROTTWEILER
Perro Bravo!!!
y el amo también.



El Problema

Control de Acceso

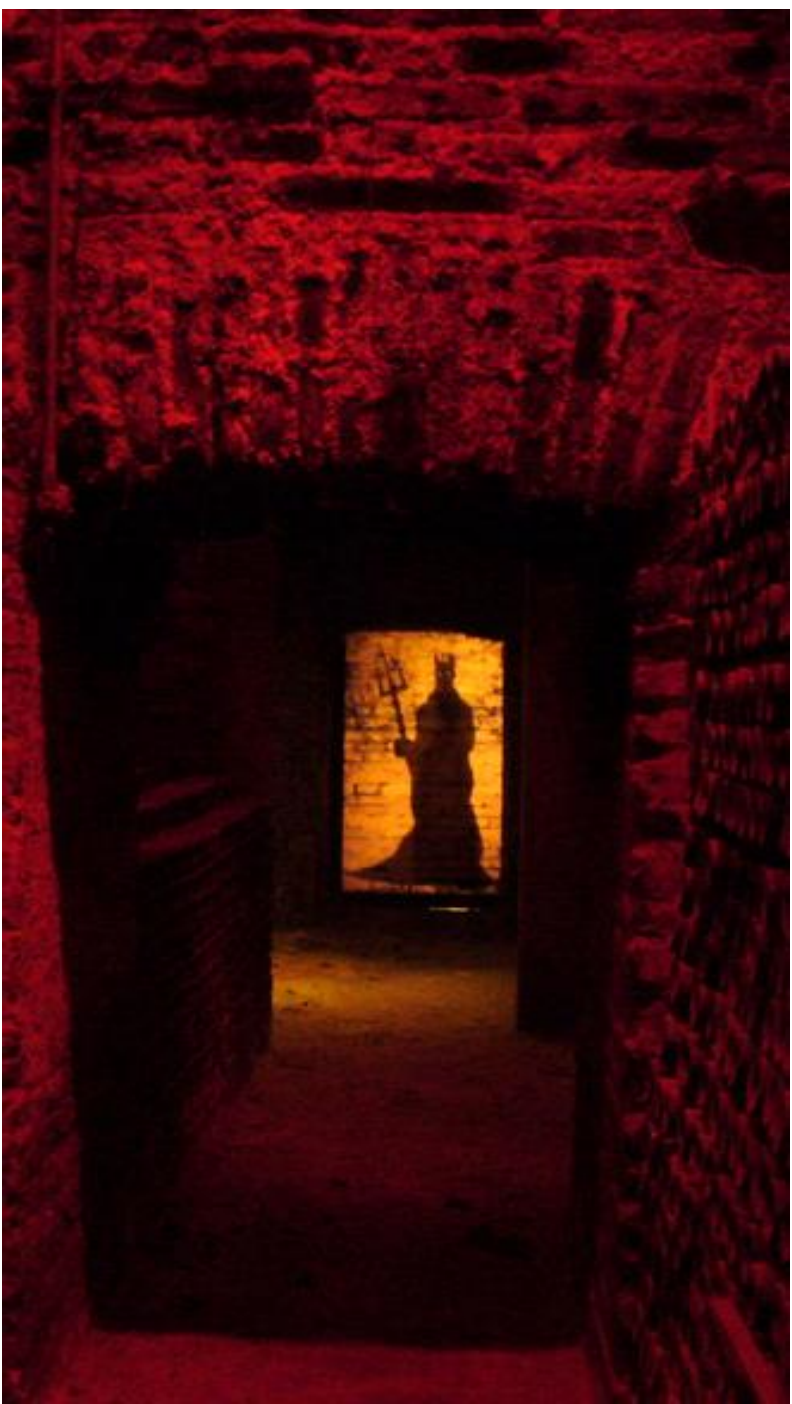
“Limitar el acceso a recursos de un sistema de información sólo a usuarios, programas, procesos u otros sistemas debidamente autorizados

[Glosario ATIS Telecom]



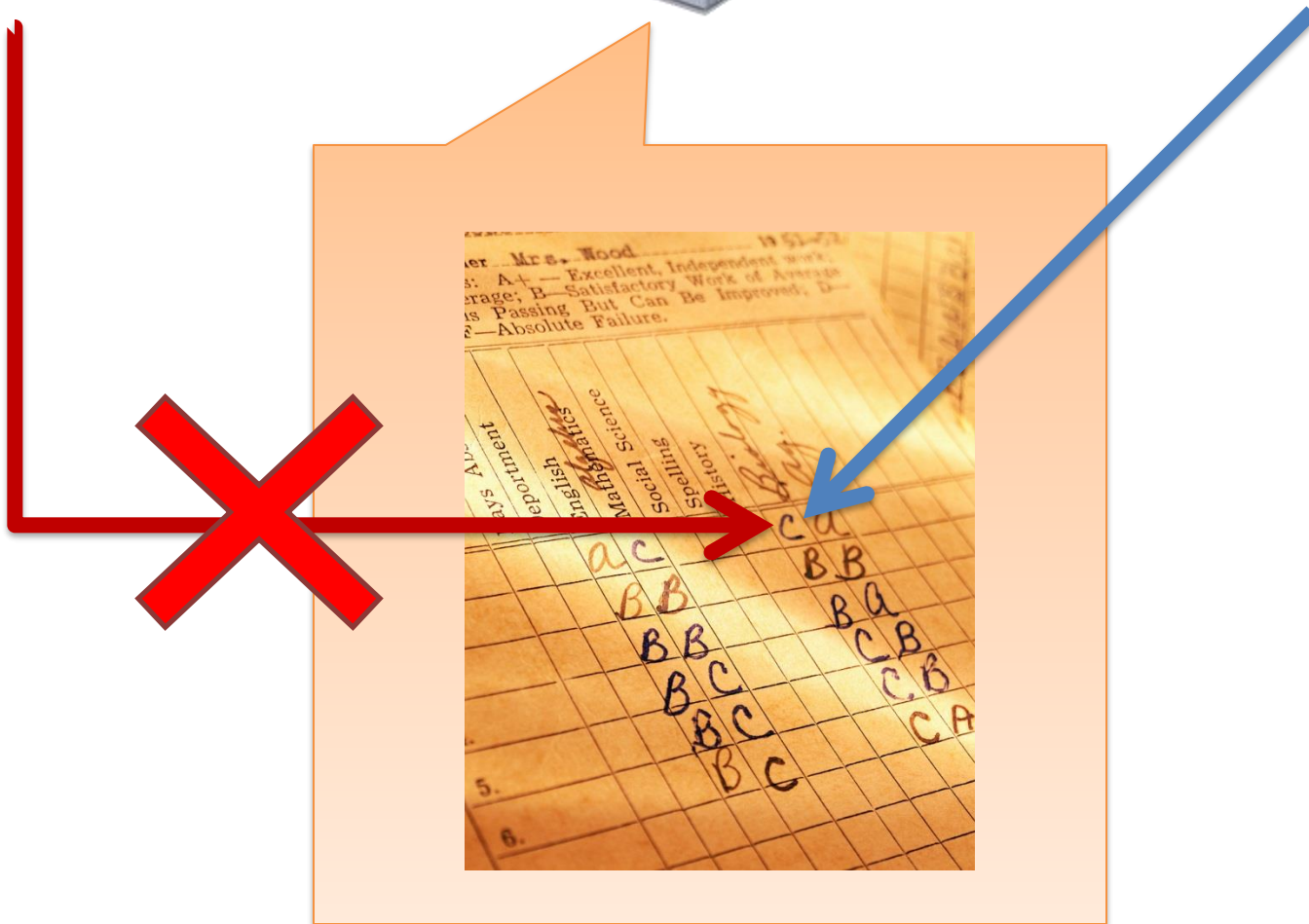
¿Cómo realizar adecuadamente
el **control de acceso**?





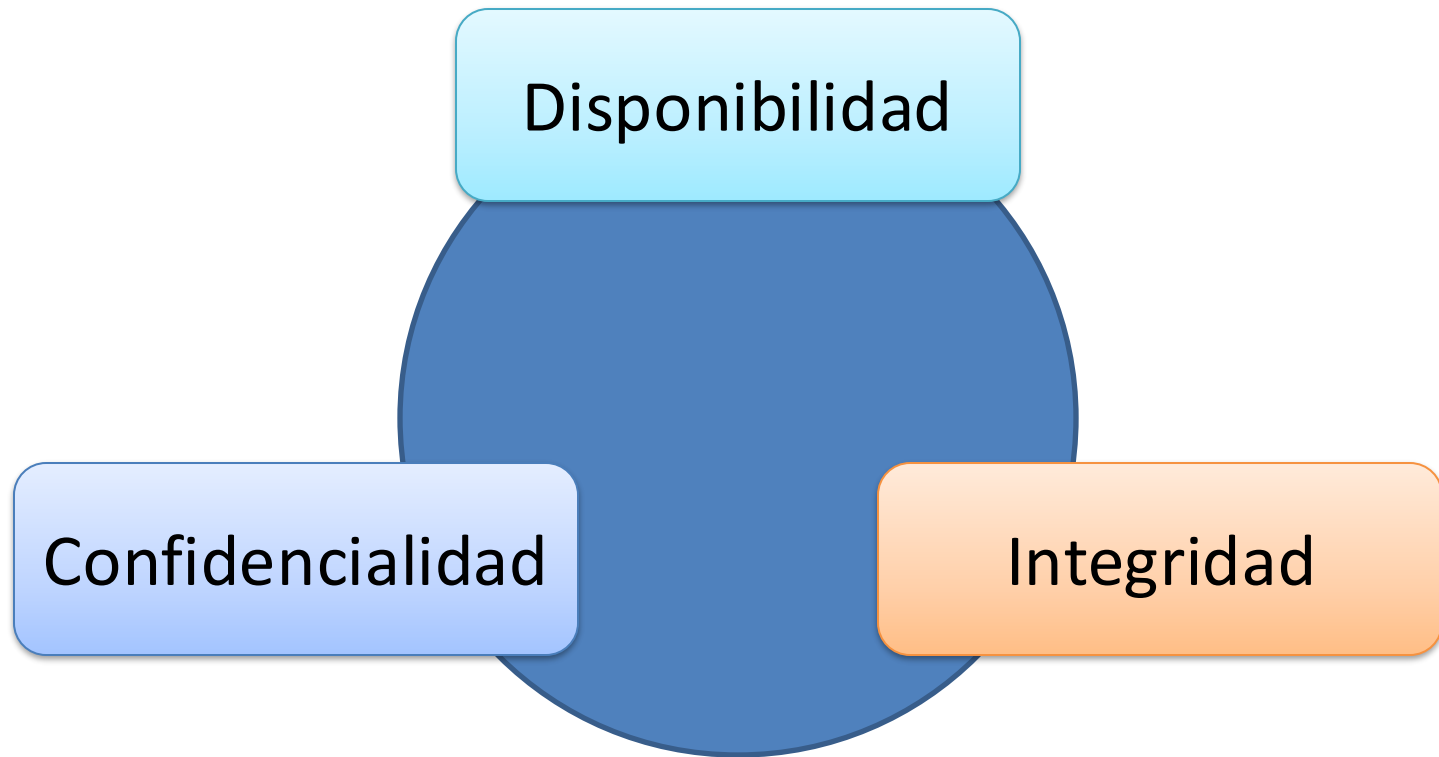
Otro poco más de historia





Conceptos básicos de seguridad

Riesgos en seguridad de la información



Disponibilidad

Redundancia
Resilencia

Confidencialidad

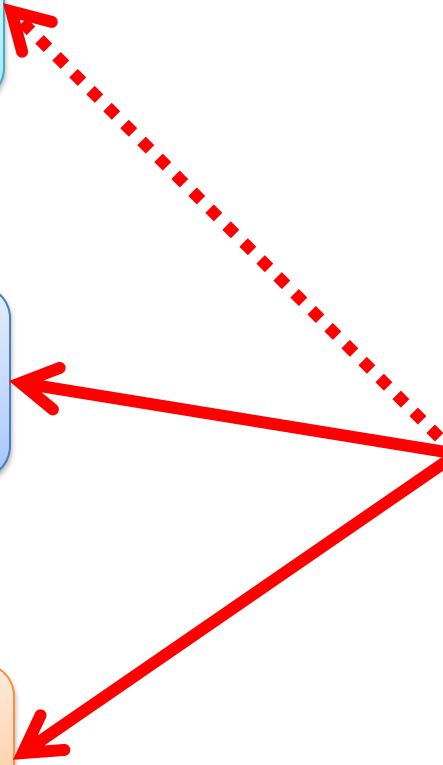
Canales seguros

Control de acceso

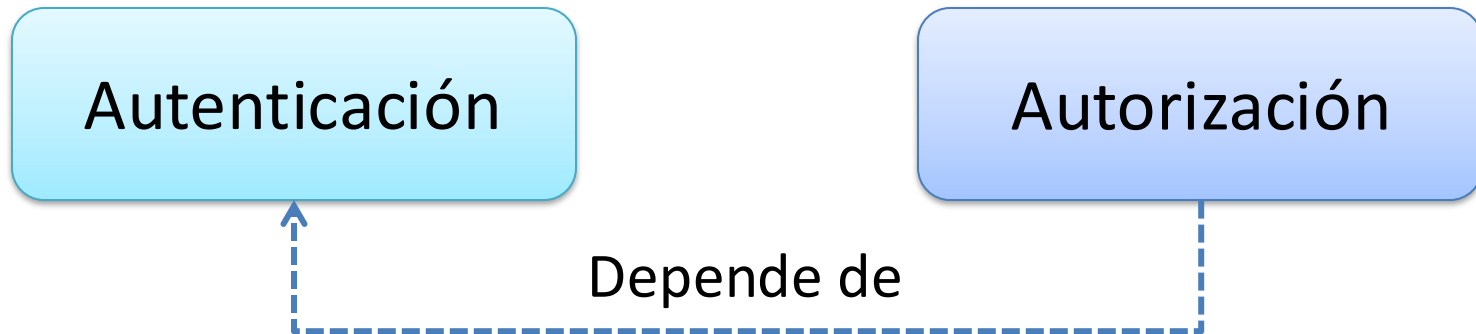
Integridad

Funciones de hashing

...



Control de acceso

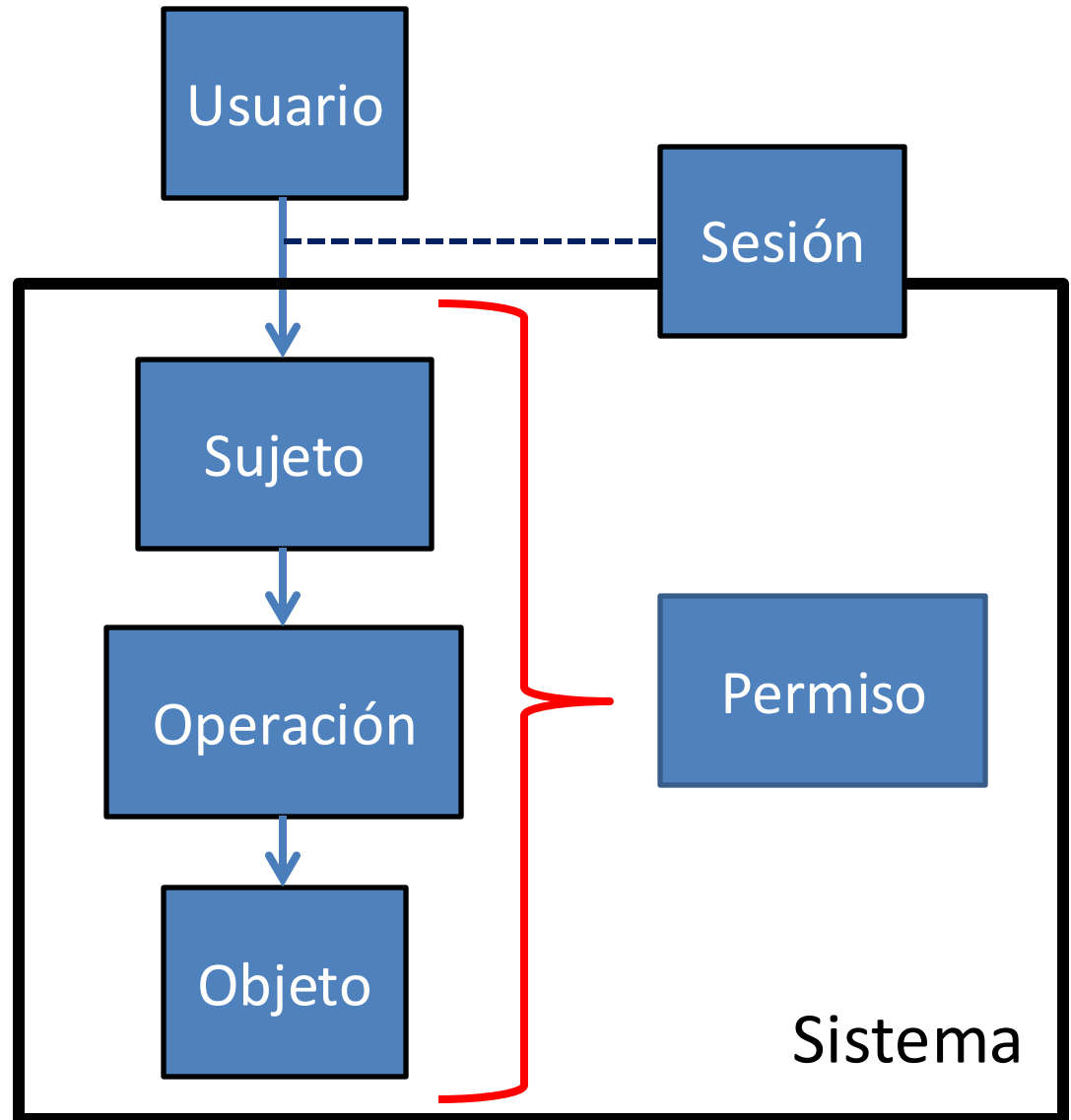


Autenticación

- Determina que la identidad del usuario es legítima
- Factores de autenticación
 - Algo que el usuario conoce
 - Contraseñas
 - Algo que el usuario tiene
 - Tarjeta de identificación
 - Clave privada (criptografía asimétrica)
 - Algo que el usuario es
 - Biometría

Autorización

- Determina qué acciones puede o no hacer el usuario
- Permisos / Privilegios

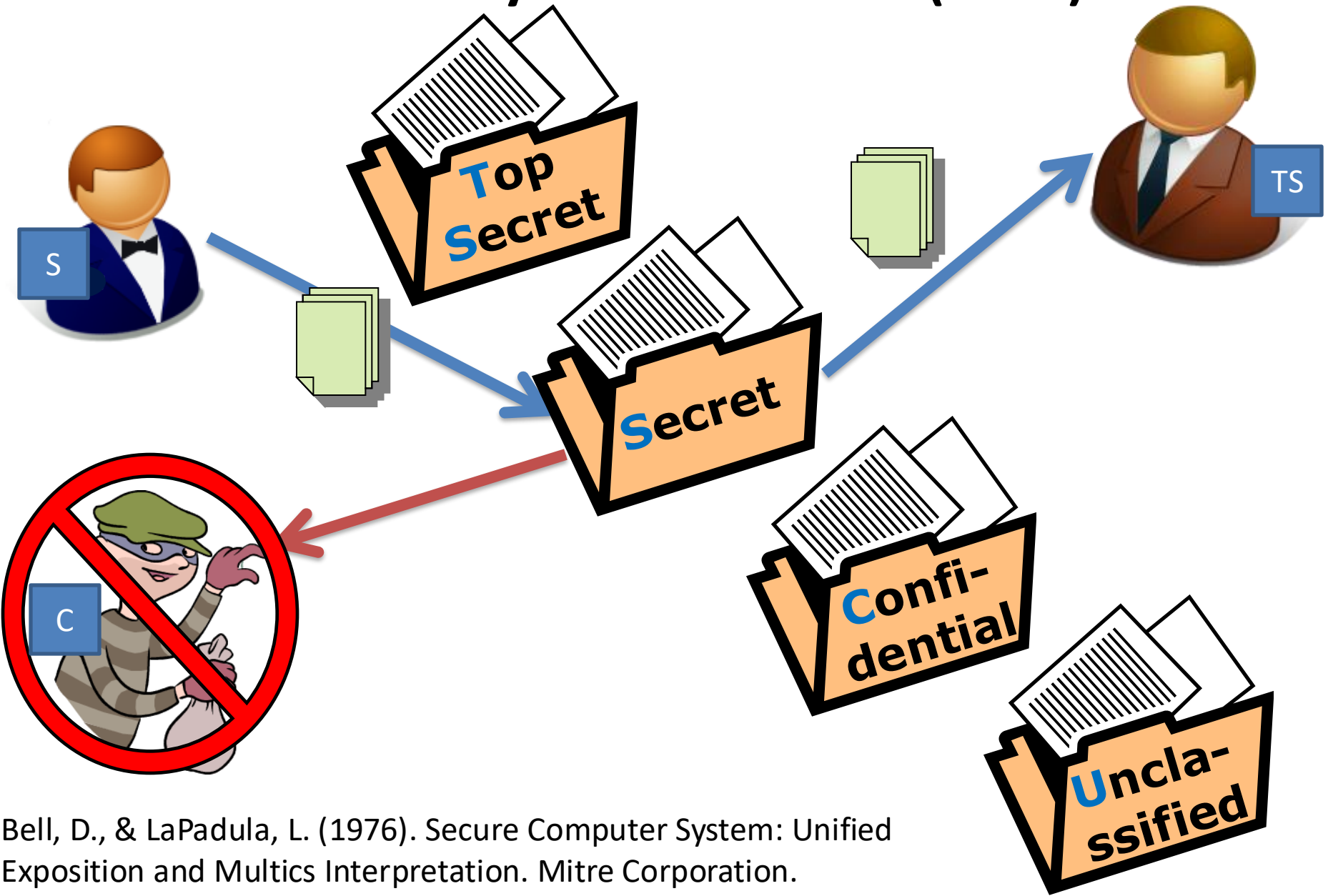


Principio de mínimo privilegio

- Asignar al usuario los mínimos privilegios requeridos para que cumpla adecuadamente sus responsabilidades

Control de acceso obligatorio

Mandatory Access Control (MAC)

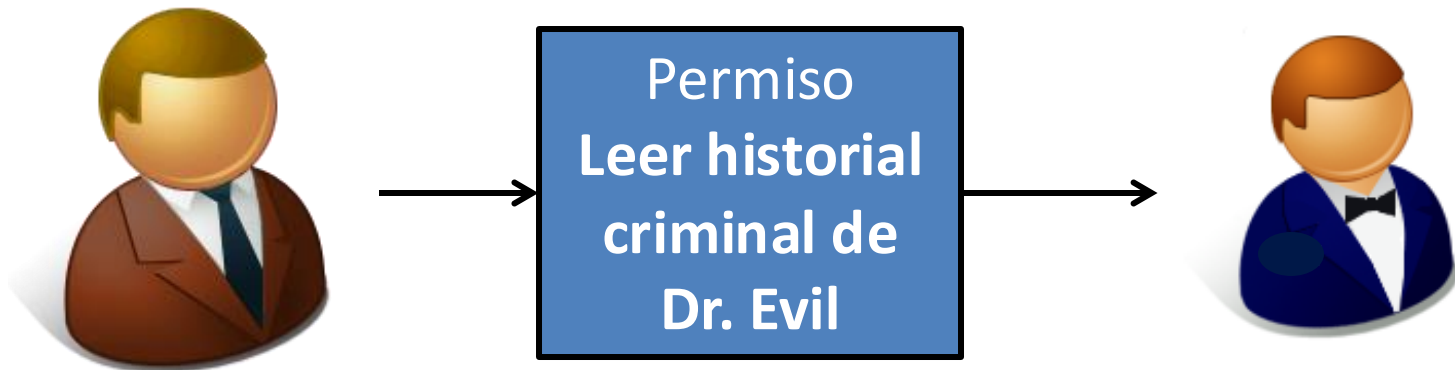


Bell, D., & LaPadula, L. (1976). Secure Computer System: Unified Exposition and Multics Interpretation. Mitre Corporation.

Control de acceso discrecional

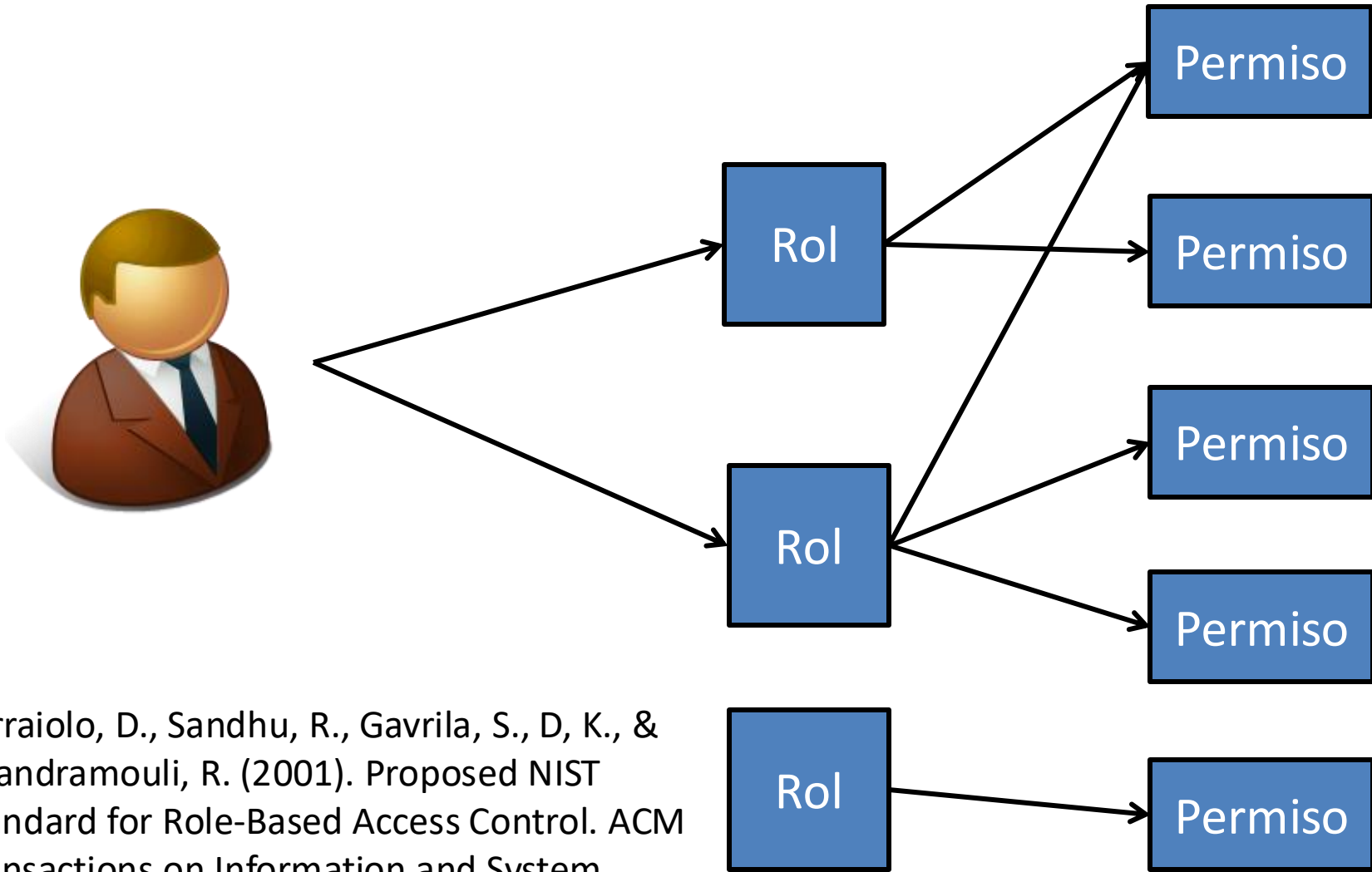
Discretionary Access Control (DAC)

- Permiso para asignar permisos a otros usuarios



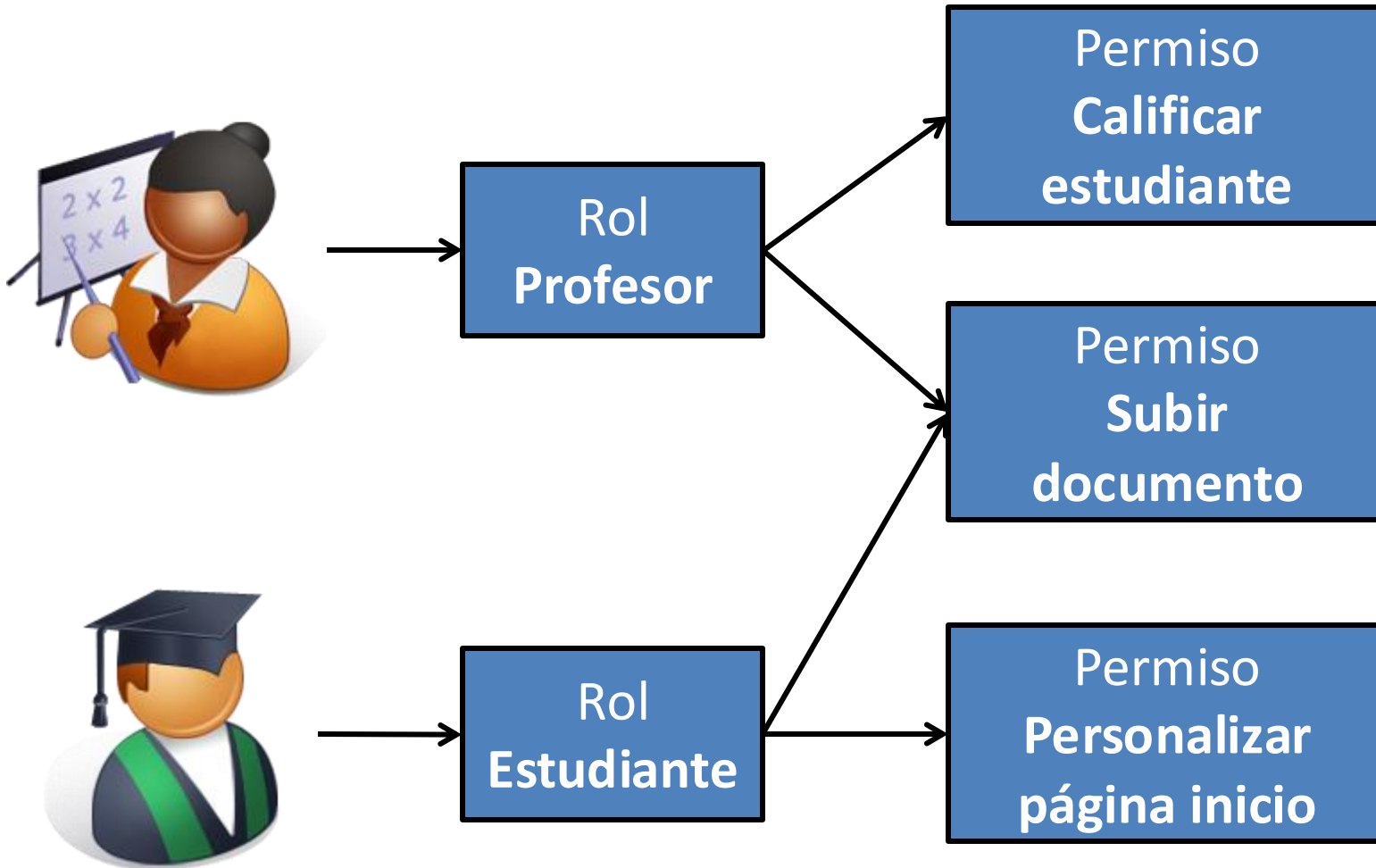
Control de acceso basado en roles

Role-Based Access Control (RBAC)



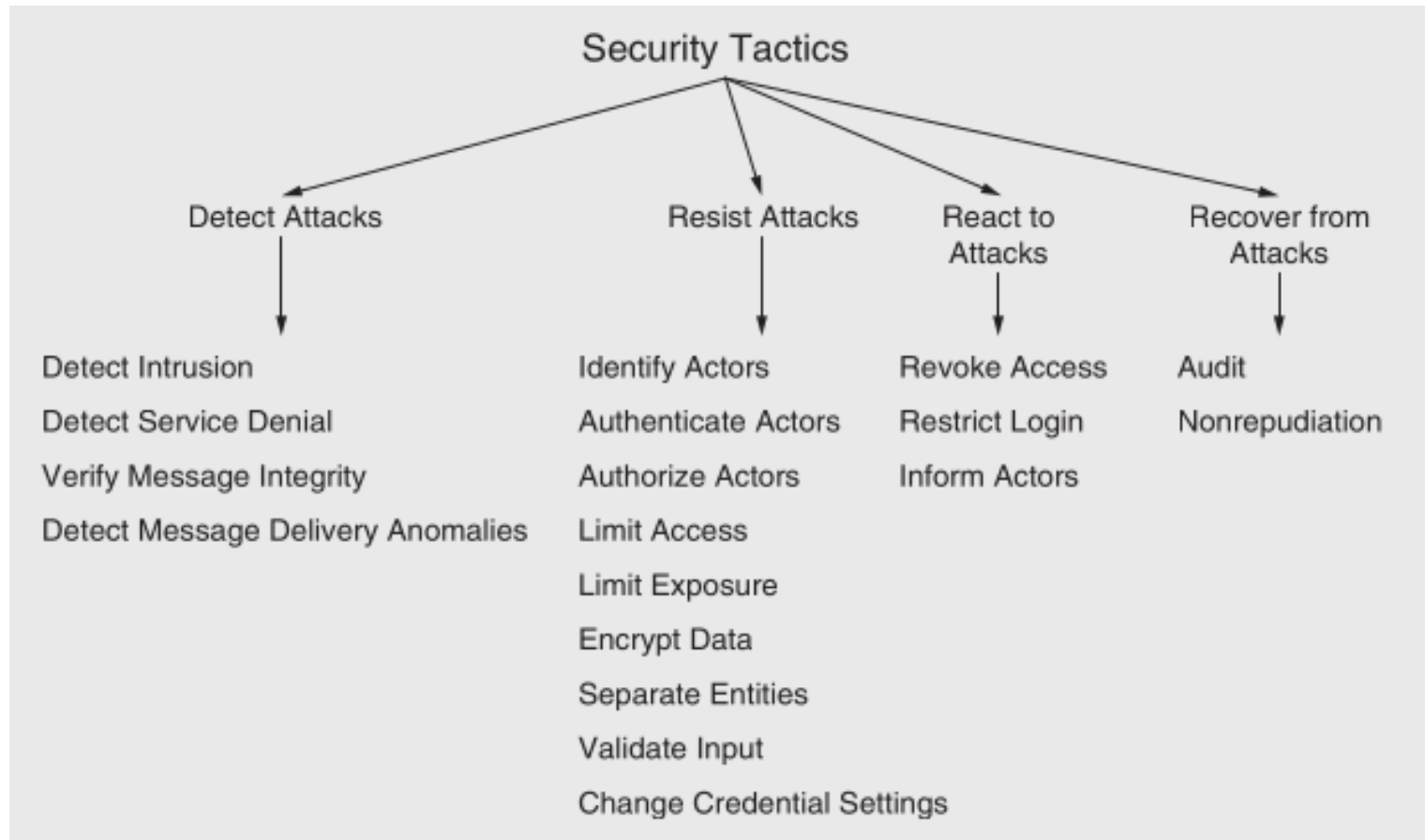
Ferraiolo, D., Sandhu, R., Gavrila, S., D, K., & Chandramouli, R. (2001). Proposed NIST Standard for Role-Based Access Control. ACM Transactions on Information and System Security, 4, 224–274.

RBAC: Ejemplo



Tácticas de Seguridad

Tácticas de Seguridad



Detectar ataques

- Detectar intrusión,
detectar denegación de servicio
 - Escanear tráfico de red
 - Detectar patrones sospechosos
- Verificar integridad de mensajes
 - Checksums, hashing. Ej. Checksums de downloads de Linux
- Detectar anomalías en transmisión de mensajes
 - Buscar patrones que evidencien "man-in-the-middle"
 - Timing, conexiones fallidas, etc.

Resistir ataques

- Identificar actores
 - Identificar origen de conexiones: ID de usuario, IP, protocolos, fingerprint
(<https://amiunique.org/fingerprint>)
- Autenticar actores
 - Determinar identidad o naturaleza del actor:
Password, tokens, 2FA, CAPTCHA etc.
- Autorizar actores
 - Limitar acceso a recursos de acuerdo al usuario o rol

Resistir ataques

- Limitar acceso
 - Restringir puntos de acceso: IP, tipo de tráfico
- Limitar exposición
 - Reducir la cantidad de recursos accesibles desde un mismo punto de acceso
 - Principio de mínimo privilegio
 - Desactivar puertos no utilizados
 - API Gateway
- Cifrar datos
 - Criptografía simétrica
 - Criptografía asimétrica
 - [Diffie-hellman key exchange](#)

Resistir ataques

- Separar entidades
 - Separación física (diferentes sub-redes)
 - VM y contenedores
 - Air gaps
- Validar entradas: Prevenir datos maliciosos, sanitizar entradas
 - [SQL Injection](#)
 - [Cross-side scripting \(XSS\)](#)
- Cambiar configuración por defecto de credenciales
 - User "admin", password "password"
- [Secure coding](#)

Reaccionar a ataques

- Revocar acceso, incluso para usuarios legítimos
- Restringir login, después de un número de intentos
- Informar actores en caso de un ataque

Recuperarse de ataques

- Todas las tácticas de recuperación de Availability
- Auditar
 - Logging: Llevar registro de las acciones de cada usuario y sus resultados
- No repudiación
 - Asegurar que las partes de una comunicación no puedan negar su participación
 - Ej: Compra online. Asegurar que comprador y vendedor no puedan negar su participación en la transacción

Patrones de seguridad

Interceptor de validación

- Intercepta mensajes
- Valida integridad, autenticidad de mensajes
- Detectar intrusiones, detectar denegación de servicio
- Ej: Spring Security Interceptors
- Ventajas
 - Protege de muchos posibles ataques
- Desventajas
 - Overhead
 - Costos mantenimiento

Sistema de prevención de intrusiones

- Componente que monitorea el sistema para identificar actividades sospechosas
 - [Snort](#)
 - [Suricata](#)
 - [Zeek](#)
 - [OSSEC](#)